

GRC102 — WEEK 1 PRACTICAL LABORATORY

Information Security Governance in Action

GHC INFORMATION SECURITY GOVERNANCE REPORT

Governance Blueprint · Information Security Charter · Board Reporting · Security Steering Committee · Governance Maturity Roadmap

GlobalHealth Connect (GHC)

Executive Governance Simulation

Prepared by: Oluwatosin Olajubu (Director of Information Security Governance)
September 2026

Table of Contents

Introduction	3
TASK 1: GOVERNANCE BLUEPRINT	4
1.1 Current-State Governance Gap Assessment	4
1.2 Proposed Information Security Governance Structure	5
1.3 RACI Matrix	5
1.4 Governance Rationale	6
TASK 2: INFORMATION SECURITY CHARTER	7
2.1 Purpose	7
2.2 Scope	7
2.3 Authority	7
2.4 Roles and Responsibilities	8
2.5 Key Principles	8
2.6 Reporting Structure	9
2.7 Review and Approval	9
2.8 CFO Justification Memo	10
TASK 3: BOARD REPORTING	11
3.1 Board Executive Summary	11
3.2 Selected Security Metrics	12
3.3 Metric Selection Rationale	14
TASK 4: SECURITY STEERING COMMITTEE	15
4.1 Security Steering Committee — Terms of Reference	15
4.2 Sample First Meeting Agenda	17
4.3 Password Policy Recommendation	17
4.4 CEO Briefing Note	18
TASK 5: GOVERNANCE MATURITY	19
5.1 Current Governance Maturity Assessment	19
5.2 12–18 Month Governance Maturity Roadmap	19
5.3 Roadmap Summary	21
5.4 Board Executive Summary	21
Conclusion	21

Introduction

GlobalHealth Connect (GHC) is a mid-sized health-technology organisation providing cloud-based patient-management systems to healthcare organisations. The organisation has experienced rapid growth, completed two acquisitions and recently experienced a contained data-leakage near-miss. These developments have highlighted weaknesses in its current ad-hoc approach to information security governance.

As the newly appointed Director of Information Security Governance, this report sets out governance arrangements that establish clear accountability, support business objectives, improve risk management and provide effective oversight at executive and Board levels.

The report is organised into five evidence bundles, corresponding to the five tasks of this practical laboratory: the Governance Blueprint (Task 1), the Information Security Charter (Task 2), Board Reporting and Security Metrics (Task 3), the Security Steering Committee (Task 4), and the Governance Maturity Assessment and Roadmap (Task 5). Together they demonstrate how GHC can transform a reactive security approach into a structured, business-aligned governance programme.

TASK 1: GOVERNANCE BLUEPRINT

1.1 Current-State Governance Gap Assessment

GHC's current information security governance model contains several significant weaknesses across leadership, oversight, risk management and cross-functional coordination. These are summarised below.

Governance Area	Current-State Gap	Governance Risk
Leadership and Accountability	Security responsibilities are not formally defined across the organisation.	Individuals may assume others are responsible for security decisions and outcomes.
Security Ownership	The IT Manager performs some security activities, but there is no dedicated governance leadership function.	Operational security activities may take priority over strategic risk management and oversight.
Board Oversight	There is no clear evidence of structured security reporting to the Board.	The Board may lack sufficient visibility of material cyber risks and governance performance.
Risk Management	Security decisions appear reactive rather than based on a formal risk management process.	Emerging threats and business risks may not be identified or treated consistently.
Policy Governance	Policies and security expectations are not clearly governed across the organisation.	Inconsistent implementation may occur across departments and acquired businesses.
Cross-Functional Coordination	Security decisions may be handled independently by IT, Development, Compliance and business functions.	Conflicting priorities may delay decisions or create inconsistent controls.
Incident Governance	Following the data-leakage near-miss, the need for clearer escalation and accountability is evident.	Delays or confusion during security incidents could increase business and regulatory impact.
Third-Party and Acquisition Governance	Rapid growth and acquisitions may introduce systems, people and processes with different security practices.	Security gaps may remain unidentified during integration.

Key Governance Gaps

The most significant weakness is the absence of a clearly defined governance structure separating strategic oversight, executive accountability and operational responsibility.

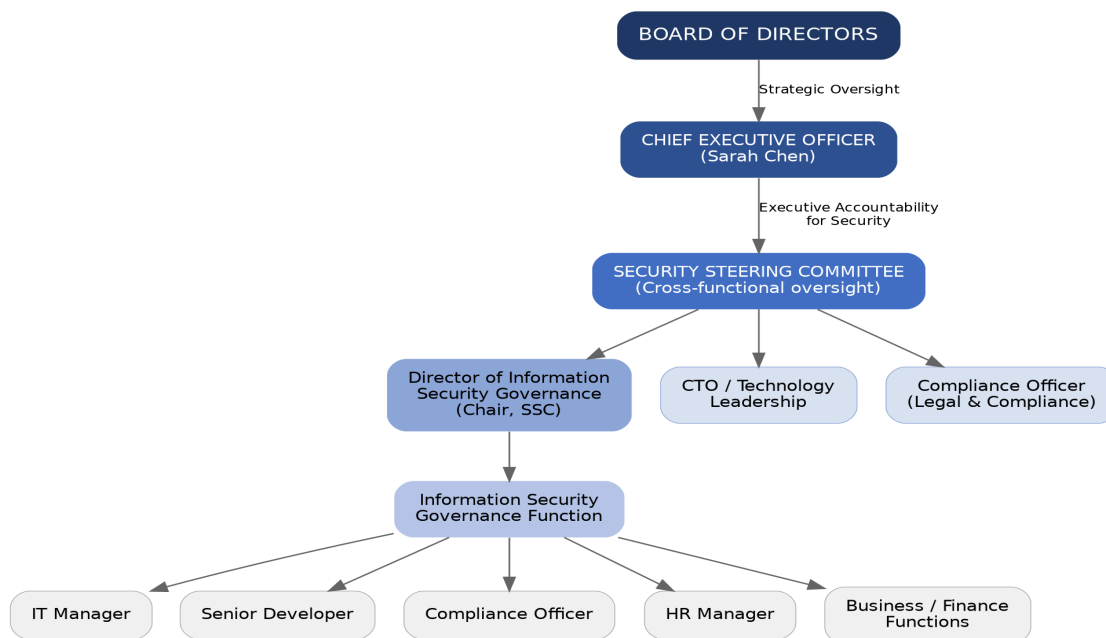
Currently, security activities appear to be concentrated primarily within IT Operations. This creates a risk that information security is viewed as an IT issue rather than an enterprise-wide business responsibility. Security governance should involve executive management, technology, compliance, human resources, finance and the Board.

Another major gap is unclear accountability. Although different stakeholders perform activities related to security, there is no formal model defining who is responsible for performing activities and who is ultimately accountable for decisions.

Finally, the current reactive approach to risk management means GHC may be responding to incidents rather than proactively identifying and managing risks before they affect the organisation.

1.2 Proposed Information Security Governance Structure

The proposed structure introduces clear lines of accountability and reporting, separating Board-level strategic oversight, executive accountability, cross-functional steering and operational delivery.



Proposed Reporting Relationships

- The Board provides strategic oversight and receives regular reports on information security risks, governance performance and material incidents.
- The CEO is accountable for ensuring that information security governance supports GHC's strategic objectives.
- The Director of Information Security Governance is responsible for coordinating the information security governance programme, managing governance processes, reporting risks and escalating significant issues.
- The Security Steering Committee provides cross-functional oversight and ensures that security decisions consider business, technology, compliance and operational requirements.
- Operational teams remain responsible for implementing security requirements within their areas of responsibility.

1.3 RACI Matrix

The RACI matrix below defines accountability for eight key information security governance activities, covering policy approval, risk oversight, incident planning, awareness, compliance, Board reporting and investment decisions.

Governance Activity	Board	CEO	Dir. ISG	CTO	IT Mgr	Compl. Officer	HR Mgr
Approve Information Security Policy	A	C	R	C	C	C	I
Review Enterprise Security Risks	A	A	R	C	C	C	I
Develop Security Policies and Standards	I	I	A/R	C	C	C	C
Incident Response Planning	I	A	A	C	R	C	C
Security Awareness Programme	I	I	A	I	C	C	R
Regulatory Compliance Monitoring	I	A	C	I	C	R	C
Security Metrics and Board Reporting	A	C	R	C	C	C	I
Security Investment Prioritisation	A	A	R	C	C	C	I

R Responsible — performs the work	A Accountable — owns the outcome and decision	C Consulted — provides input before a decision	I Informed — kept up to date after a decision
--	--	---	--

1.4 Governance Rationale

The proposed governance structure improves accountability by clearly distinguishing between oversight, accountability and operational responsibility. The Board provides strategic oversight, executive management ensures alignment with organisational objectives and operational teams implement security controls.

Transparency is improved through formal reporting structures and the Security Steering Committee. Significant risks, incidents and performance issues can be escalated through defined channels rather than remaining isolated within technical teams.

The structure also supports business alignment. GHC's strategic objectives include market expansion, operational efficiency, customer trust, innovation and regulatory excellence. Security governance must therefore support these objectives rather than operate independently from them.

Finally, the proposed model improves risk management by introducing regular risk review, defined decision-making authority and cross-functional participation.

TASK 2: INFORMATION SECURITY CHARTER

2.1 Purpose

The purpose of the GlobalHealth Connect Information Security Programme is to protect the confidentiality, integrity and availability of the organisation's information, systems and services.

The programme supports GHC's strategic objectives by protecting sensitive patient and organisational information, maintaining customer trust, supporting regulatory compliance, enabling secure innovation and reducing the risk of security incidents that could disrupt business operations.

Information security governance will operate as a business-enabling function that supports responsible growth and informed decision-making.

2.2 Scope

This Charter applies to all information assets and activities associated with GlobalHealth Connect, including:

- Patient and healthcare-related information
- Customer and employee information
- Cloud infrastructure and applications
- Networks, endpoints and technology platforms
- Software development and digital products
- Employees, contractors and temporary personnel
- Third-party service providers and suppliers
- Acquired businesses and newly integrated systems
- Physical and digital information assets

All personnel and relevant third parties are expected to comply with applicable information security policies and requirements.

2.3 Authority

The Information Security Programme derives its authority from executive management and the Board of Directors.

The Director of Information Security Governance is authorised to:

- Develop and maintain information security governance policies and standards
- Coordinate organisation-wide security risk assessments
- Monitor security governance performance
- Escalate significant risks and control weaknesses
- Recommend corrective actions and security investments
- Report material security matters to executive management and the Board
- Coordinate cross-functional security governance activities

Material risks that exceed management's authority or risk tolerance must be escalated to the CEO and, where appropriate, the Board.

2.4 Roles and Responsibilities

Role	Responsibility
Board of Directors	Provides strategic oversight of information security governance, approves significant policies and receives reports on material security risks.
Chief Executive Officer	Accountable for ensuring that information security governance supports GHC's strategic objectives and receives appropriate executive attention.
Director of Information Security Governance	Responsible for coordinating the Information Security Programme, maintaining governance processes, facilitating risk management and providing management and Board reporting.
Chief Technology Officer	Ensures that technology and product development activities incorporate appropriate security requirements while supporting innovation and operational objectives.
IT Manager	Responsible for implementing and maintaining operational security controls within IT infrastructure and operations.
Compliance Officer	Supports the identification and monitoring of applicable regulatory and legal obligations.
Human Resources Manager	Supports security-related responsibilities involving employee onboarding, offboarding and security awareness.
Employees and Contractors	Responsible for complying with applicable security policies and reporting suspected security incidents or weaknesses.

2.5 Key Principles

The Information Security Programme will operate according to the following principles:

1. Risk-Based Security decisions and investments should be based on the level of risk to GHC's business objectives, assets and stakeholders.	2. Business-Aligned Information security should support organisational growth, innovation, operational efficiency and customer trust.
3. Proportionate Security controls should be appropriate to the nature of the risk and should avoid unnecessary operational burden.	4. Accountable Roles, responsibilities and decision-making authority must be clearly defined.
5. Transparent	6. Continuously Improving

Significant security risks and performance issues must be communicated to appropriate stakeholders.	The Information Security Programme will be reviewed regularly and improved in response to changing business requirements, threats and lessons learned.
---	--

2.6 Reporting Structure

Information security performance and risks will be reported through the following governance structure:

- Operational issues will be managed by relevant business and technology teams.
- Cross-functional security issues will be reviewed by the Security Steering Committee.
- Significant risks and programme performance will be reported to executive management.
- Material risks, incidents and strategic issues will be reported to the Board.

Board reporting will focus on business impact, material risks, governance performance and strategic decisions rather than unnecessary technical detail.

2.7 Review and Approval

This Charter will be approved by executive management and endorsed by the Board.

The Charter will be formally reviewed at least annually or earlier where significant organisational, regulatory or technological changes occur.

Changes to the Charter must follow the established governance and approval process.

2.8 CFO Justification Memo

To: Marcus Thorne, Chief Financial Officer
From: Director of Information Security Governance
Date: September 2026
Subject: Justification for the GlobalHealth Connect Information Security Charter

The proposed Information Security Charter provides GHC with a formal mandate for managing information security as the organisation continues to grow, expand into new markets and invest in digital innovation. The Charter establishes clear authority, accountability and reporting arrangements, reducing the risk of fragmented decision-making across IT, Development, Compliance and other business functions.

From a financial and investment perspective, the Charter supports more informed decision-making by linking security investments to business risks and strategic priorities. It will help management prioritise resources based on risk, regulatory requirements and business impact rather than responding only after incidents occur. This is particularly important as GHC seeks to protect customer trust, achieve regulatory excellence and maintain operational resilience while pursuing growth and innovation.

TASK 3: BOARD REPORTING

3.1 Board Executive Summary

Overall Security Posture:

RED

GHC's overall information security posture is assessed as Red. The six-month security data indicates a deteriorating threat environment and increasing exposure to cyber risk. Phishing activity has increased from 150 incidents in September to 320 in February. Malware incidents have doubled from 25 to 50 over the same period. High-risk security incidents have also increased from two to seven.

At the same time, the organisation's patching performance has declined from 67% to 55%, despite an increasing number of critical vulnerabilities requiring remediation. Although security awareness training completion has improved from 45% to 70%, this improvement has not yet translated into a reduction in phishing or malware activity.

The combination of increasing threats, declining patching performance and rising high-risk incidents presents a significant risk to GHC's operations, sensitive patient information and customer trust.

Priority Risks

- Increasing exposure to cyber incidents due to the growing number of phishing and malware events.
- Delayed remediation of critical vulnerabilities due to declining patching performance.

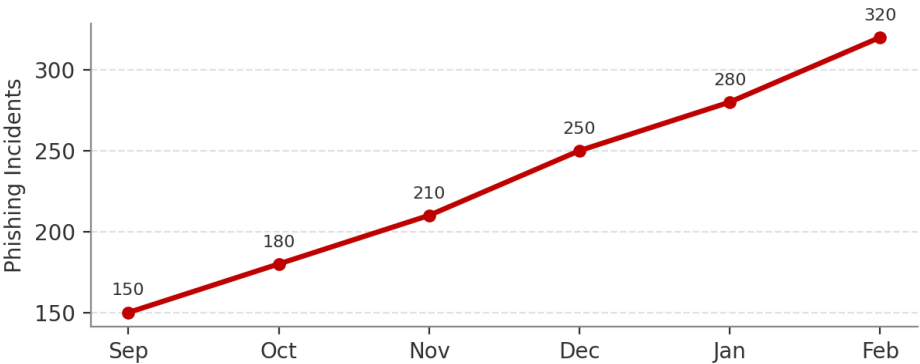
Board-Level Recommendations

- Prioritise investment in vulnerability remediation and establish clear accountability for critical patching performance.
- Strengthen phishing and malware prevention through improved technical controls, targeted awareness training and regular monitoring.
- Require monthly executive review of high-risk incidents and remediation progress until security performance improves.

3.2 Selected Security Metrics

Metric 1: Phishing Incidents

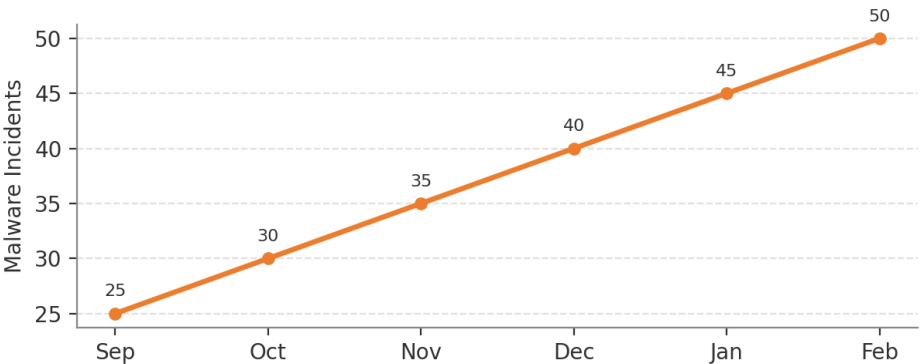
	Sep	Oct	Nov	Dec	Jan	Feb
Phishing Incidents	150	180	210	250	280	320



Trend: Increasing significantly.
Phishing incidents increased by more than 100% over six months. This indicates that GHC's exposure to social engineering attacks is growing and could result in credential compromise, financial loss or unauthorised access to sensitive information.

Metric 2: Malware Incidents

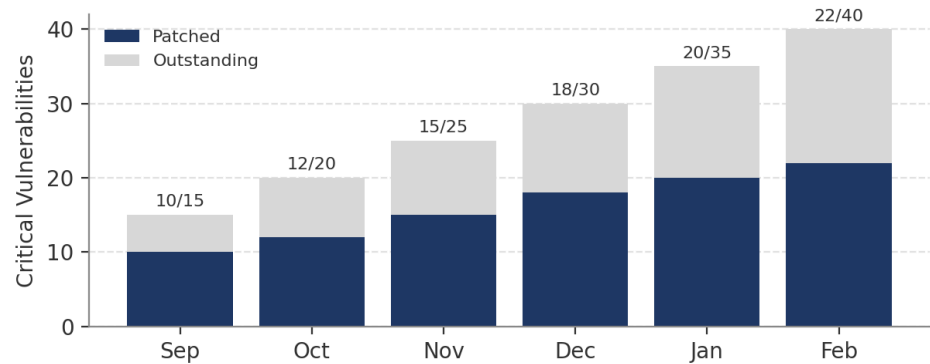
	Sep	Oct	Nov	Dec	Jan	Feb
Malware Incidents	25	30	35	40	45	50



Trend: Consistently increasing.
Malware incidents doubled during the reporting period. This suggests increasing exposure and potentially insufficient preventative or detection controls.

Metric 3: Critical Vulnerabilities Patched

	Sep	Oct	Nov	Dec	Jan	Feb
Patched of Total	10 of 15	12 of 20	15 of 25	18 of 30	20 of 35	22 of 40

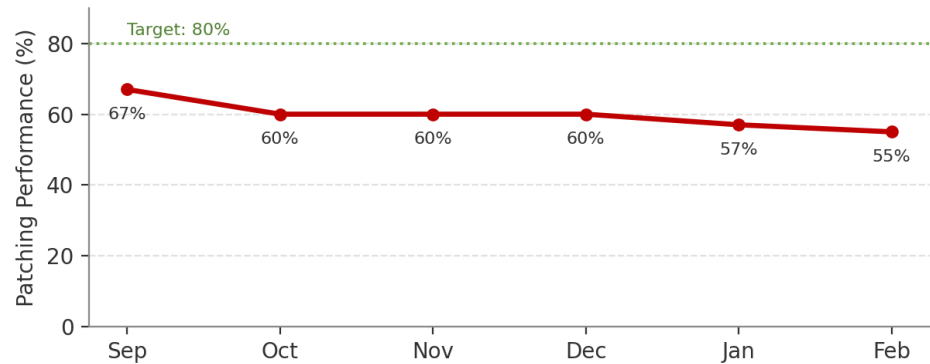


Trend: The number of vulnerabilities being addressed is increasing, but the backlog is growing faster than remediation efforts.

The organisation is identifying and patching vulnerabilities, but the number of outstanding critical vulnerabilities continues to increase. This creates a growing attack surface and requires management attention.

Metric 4: Patching Performance

	Sep	Oct	Nov	Dec	Jan	Feb
Patching Performance	67%	60%	60%	60%	57%	55%

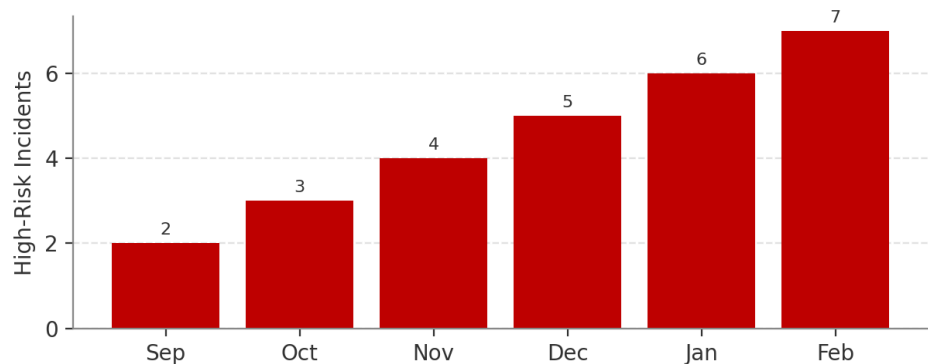


Trend: Declining.

Patching performance has declined from 67% to 55%. Given the increasing number of critical vulnerabilities, this represents a significant governance concern and increases the likelihood of exploitation.

Metric 5: High-Risk Security Incidents

	Sep	Oct	Nov	Dec	Jan	Feb
High-Risk Security Incidents	2	3	4	5	6	7



Trend: Increasing consistently.

High-risk incidents have increased steadily throughout the reporting period. This is the most significant Board-level outcome metric because it demonstrates that security risks are increasingly translating into incidents with potentially material business impact.

3.3 Metric Selection Rationale

The five selected metrics were chosen because they provide the Board with a balanced view of threat exposure, control effectiveness and business risk.

Phishing and malware incidents demonstrate changes in the external and internal threat environment. Critical vulnerability remediation and patching performance provide insight into GHC's ability to manage known technical weaknesses. High-risk incidents provide an outcome-focused measure of whether security risks are affecting the organisation.

These metrics are suitable for Board oversight because they show trends over time and can support strategic decisions regarding investment, risk prioritisation and management accountability.

TASK 4: SECURITY STEERING COMMITTEE

4.1 Security Steering Committee — Terms of Reference

Name

GlobalHealth Connect Security Steering Committee (SSC)

Purpose

The purpose of the Security Steering Committee is to provide cross-functional leadership, oversight and decision-making for significant information security matters affecting GHC.

The Committee will ensure that security decisions balance business objectives, technology requirements, risk management and regulatory obligations.

Scope

The SSC will consider:

- a. Information security strategy and priorities
- b. Significant security risks
- c. Major policies and standards
- d. Security investment priorities
- e. Cross-functional security issues
- f. Significant incidents and lessons learned
- g. Regulatory and compliance matters
- h. Security programme performance
- i. Emerging technology and business risks

Membership

The proposed membership includes:

1. Chief Executive Officer or nominated executive sponsor
2. Director of Information Security Governance — Chair
3. Chief Technology Officer
4. IT Manager
5. Compliance Officer
6. HR Manager
7. Finance representative, where relevant
8. Other subject-matter experts, as required

Responsibilities

The SSC will:

- a. Provide strategic direction for the Information Security Programme.
- b. Review significant information security risks.
- c. Resolve cross-functional security issues.
- d. Review and recommend major security policies.
- e. Prioritise security initiatives and investments.
- f. Monitor security performance and improvement activities.
- g. Ensure alignment between security objectives and business strategy.
- h. Escalate material risks to executive management and the Board.

Meeting Cadence

The Committee will meet monthly. Additional meetings may be convened where significant incidents, risks or urgent decisions require immediate attention.

Decision Authority

The SSC may approve operational and cross-functional security decisions within its delegated authority.

Strategic decisions involving significant financial investment, risk acceptance or material organisational impact will be escalated to executive management or the Board where necessary.

Reporting

The SSC will provide regular updates to executive management. Material risks, major incidents and significant governance issues will be included in Board reporting.

4.2 Sample First Security Steering Committee Meeting Agenda

Committee: GlobalHealth Connect Security Steering Committee

Meeting: Meeting 1

Date: 15-09-2026

Time: 15-09-2026

Chair: Director of Information Security Governance

Agenda Item	Discussion
1. Opening and Introductions	Introduction of members and confirmation of Committee purpose.
2. Approval of Terms of Reference	Review and approval of SSC mandate, membership and decision authority.
3. Current Security Posture	Overview of key risks, incidents and governance priorities.
4. Password Policy Conflict	Discussion between CTO and IT Manager regarding proposed password requirements.
5. Risk-Based Password Policy Proposal	Consider adoption of MFA and password-manager integration rather than mandatory 30-day password changes.
6. Security Metrics	Review of current security performance trends.
7. Priority Governance Actions	Agreement on immediate priorities and responsible owners.
8. Next Steps	Confirmation of action items and next meeting date.

4.3 Password Policy Recommendation

The proposed requirement for 16-character complex passwords changed every 30 days without password-manager integration is likely to create unnecessary user friction and may encourage insecure behaviour, such as password reuse or unsafe password storage.

A more balanced approach would include:

- Strong minimum password requirements
- Multi-factor authentication
- Password-manager integration
- Risk-based monitoring
- Password changes where compromise or risk indicators exist rather than mandatory frequent changes for all users

This approach better balances security and usability while supporting productivity.

4.4 CEO Briefing Note

To: Sarah Chen, Chief Executive Officer
From: Director of Information Security Governance
Date: September 2026
Subject: Establishment of the Security Steering Committee

The proposed Security Steering Committee will provide GHC with a formal mechanism for resolving security issues that affect multiple business functions. The current disagreement between the CTO and IT Manager regarding password requirements demonstrates why security decisions should not be made by one function in isolation.

The SSC will bring together executive, technology, IT, compliance and business stakeholders to evaluate issues using a risk-based and business-aligned approach. This will improve decision-making, reduce conflicts between competing priorities and ensure that security controls support both organisational protection and strategic objectives. Significant unresolved issues can then be escalated through appropriate executive or Board governance channels.

TASK 5: GOVERNANCE MATURITY

5.1 Current Governance Maturity Assessment

Governance Domain	Current Evidence	Current Maturity	Target
Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.	Level 1 – Ad Hoc	Level 3 – Defined
Roles & Responsibilities	Security ownership and accountability are unclear.	Level 1 – Ad Hoc	Level 3 – Defined
Risk Management	Organisation is reactive and lacks a formal proactive assessment process.	Level 1 – Ad Hoc	Level 3 – Defined
Metrics & Reporting	Technical metrics exist but are not consistently linked to business impact.	Level 2 – Initial	Level 3 – Defined
Training & Awareness	Training is mandatory, but engagement is low.	Level 2 – Initial	Level 3 – Defined
Compliance	Compliance preparation is audit-driven rather than continuously monitored.	Level 1 – Ad Hoc	Level 3 – Defined

Overall Maturity Assessment

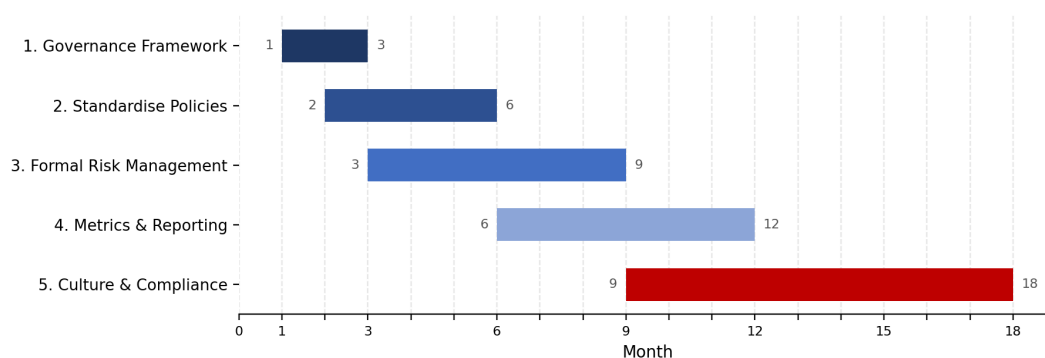
GHC's overall governance maturity is between Level 1 (Ad Hoc) and Level 2 (Initial).

Some security activities and processes exist, particularly technical metrics and mandatory training. However, these processes are inconsistent and lack sufficient integration, documentation and accountability.

The organisation's primary challenge is moving from reactive practices to defined and repeatable governance processes.

The immediate Objective is to achieve Level 3 (Defined) Maturity across all 6 governance domains within 12-18 months.

5.2 12–18 Month Governance Maturity Roadmap



Initiative 1: Establish the Information Security Governance Framework

Objective: Create a formal governance structure with defined accountability and reporting.

Key Activities:

- Approve the Information Security Charter.
- Establish the Security Steering Committee.
- Define governance roles and responsibilities.

- Implement the RACI model.
- Establish regular executive and Board reporting.

Expected Outcome: Clear governance accountability and structured oversight across the organisation.

Timeline: Months 1–3

Initiative 2: Standardise Policies and Documentation

Objective: Create a consistent and centrally governed policy framework.

Key Activities:

- Review existing policies inherited from acquisitions.
- Identify outdated or inconsistent documentation.
- Develop a central policy management process.
- Assign policy owners.
- Establish review and approval cycles.

Expected Outcome: All critical information security policies are documented, approved, current and assigned to accountable owners.

Timeline: Months 2–6

Initiative 3: Implement a Formal Security Risk Management Process

Objective: Move from reactive risk management to proactive identification and treatment of information security risks.

Key Activities:

- Develop a formal risk assessment methodology.
- Establish a security risk register.
- Define risk ownership.
- Introduce periodic risk reviews.
- Establish escalation thresholds for significant risks.

Expected Outcome: Security risks are consistently identified, assessed, treated and monitored.

Timeline: Months 3–9

Initiative 4: Improve Security Metrics and Management Reporting

Objective: Develop meaningful metrics that support executive and Board decision-making.

Key Activities:

- Define key risk and performance indicators.
- Establish reporting thresholds.
- Link technical metrics to business impact.
- Introduce monthly management reporting.
- Introduce quarterly Board reporting.

Expected Outcome: Decision-makers receive consistent and meaningful information about security performance and risk.

Timeline: Months 6–12

Initiative 5: Strengthen Security Culture and Compliance Monitoring

Objective: Improve employee engagement and transition from audit-driven compliance to continuous monitoring.

Key Activities:

- Improve awareness training content.
- Introduce targeted training based on risk.
- Conduct awareness simulations and assessments.
- Establish compliance monitoring activities.
- Track remediation of identified compliance gaps.

Expected Outcome: Improved security awareness, stronger employee engagement and continuous visibility of compliance obligations.

Timeline: Months 9–18

5.3 Roadmap Summary

Period	Priority Focus
Months 1–3	Governance structure, Charter, RACI and Security Steering Committee
Months 2–6	Policy and documentation standardisation
Months 3–9	Formal risk management process
Months 6–12	Metrics, reporting and management oversight
Months 9–18	Security culture and continuous compliance monitoring

5.4 Board Executive Summary

GlobalHealth Connect currently operates at an overall governance maturity level between Ad Hoc and Initial. While some information security activities exist, governance processes are inconsistent, accountability is unclear and security risk management remains largely reactive.

The proposed 12–18 month roadmap is designed to move GHC to at least Level 3 (Defined) maturity across all governance domains. The roadmap prioritises the establishment of formal governance structures, standardised policies, proactive risk management, meaningful Board reporting and continuous compliance monitoring.

Achieving this level of maturity is strategically important because GHC is expanding, integrating acquisitions and investing in new technologies. Without stronger governance, the organisation may struggle to manage increasing security, regulatory and operational risks. The roadmap therefore provides a practical foundation for sustainable growth, customer trust and long-term organisational resilience.

Conclusion

The governance challenges facing GlobalHealth Connect demonstrate that information security cannot be effectively managed through isolated technical activities alone. As the organisation grows, information security must become an integrated governance function supported by the Board, executive management and operational teams.

The proposed governance blueprint establishes clear accountability and reporting relationships. The Information Security Charter provides a formal mandate for the security programme. Board-level reporting ensures that significant risks and trends are communicated in business-focused terms. The Security Steering Committee provides a mechanism for resolving

cross-functional conflicts, while the maturity roadmap establishes a practical path towards more consistent and measurable governance.

Together, these initiatives will help GHC move from a reactive security model towards a structured, business-aligned and continuously improving information security governance programme.